

Axiom AI Technologies

Information Security Management System (ISMS) Implementation Summary

Document Field	Value
Document Title	ISMS Implementation Summary
Organization	Axiom AI Technologies
ISMS Framework	ISO/IEC 27001:2022
Document Status	Implementation Summary
Version	1.0
Document Owner	Information Security / GRC Function
Classification	Internal Use

1. Executive Summary

Axiom AI Technologies has established a modeled Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022. The implementation integrates information security governance, risk management, control assessment, security policies, defined responsibilities, and an initial Statement of Applicability (SoA).

The ISMS provides a structured, risk-based approach to protecting the confidentiality, integrity, and availability of information supporting Axiom AI's cloud-based SaaS environment.

The current implementation is an **ISMS implementation in progress**. Several controls remain partially implemented or planned and are subject to remediation, evidence development, and effectiveness validation.

2. ISMS Implementation Approach

The implementation followed a structured sequence designed to maintain traceability between business risks, security controls, governance requirements, and supporting documentation.

The implementation follows this general lifecycle:

Asset Inventory → Risk Assessment → Control Assessment → Policy Development → ISMS Governance → Statement of Applicability → Remediation → Continual Improvement

Asset and risk information informed the control assessment. Control findings informed remediation activities and policy requirements. The resulting policies, objectives, responsibilities, and Statement of Applicability establish the governance foundation for continual improvement.

3. ISMS Implementation Components

3.1 Risk Management

An asset inventory and risk register were developed to identify information assets, threats, vulnerabilities, impacts, likelihood, risk ratings, and treatment activities.

The risk management process provides the foundation for determining which security controls require implementation or improvement.

3.2 Control Assessment

A 40-control security control assessment was performed against the modeled Axiom AI environment.

The assessment evaluated control effectiveness and identified areas requiring remediation or additional implementation activities.

Assessment results were categorized according to control effectiveness and remediation status.

3.3 Policy Framework

The core ISMS policy framework includes:

- Information Security Policy
- Access Control Policy
- Incident Response Policy
- Asset Management Policy
- Third-Party Security Policy

These policies establish organizational requirements for employees, contractors, management, and relevant third parties.

3.4 ISMS Scope

The ISMS Scope Statement defines the organizational, technological, and information boundaries of the modeled ISMS.

The scope provides the basis for determining which activities, systems, assets, processes, and security requirements are included within the ISMS.

3.5 ISMS Objectives

Information security objectives were established to provide measurable direction for the ISMS.

The objectives address areas including:

- Risk management
- Control effectiveness
- Access management
- Vulnerability remediation
- Incident response
- Business continuity
- Third-party security
- Security awareness
- Security monitoring
- ISMS compliance and continual improvement

3.6 Roles and Responsibilities

ISMS responsibilities were assigned across relevant organizational functions, including:

- Executive Management
- Information Security / GRC
- Engineering and IT
- System and Asset Owners
- HR
- Procurement
- Risk Owners
- Control Owners
- Employees
- Contractors
- Third Parties

The defined responsibilities establish accountability for implementing, maintaining, reviewing, and improving information security controls.

3.7 Statement of Applicability

The Statement of Applicability evaluates the applicability and implementation status of all **93 ISO/IEC 27001:2022 Annex A controls**.

The SoA also connects applicable controls to relevant policies, risks, implementation activities, control owners, and evidence.

4. ISMS Governance Model

The ISMS is governed through management oversight, defined information security responsibilities, risk ownership, control ownership, periodic review, and continual improvement.

Executive Management provides direction, resources, and risk acceptance authority.

The ISMS Owner and GRC function coordinate ISMS activities, while technical and business owners are responsible for implementing and operating controls within their respective areas.

Employees and contractors are responsible for following applicable information security policies and reporting security events or concerns through established channels.

5. Current Implementation Status

The modeled ISMS should be considered an **implementation in progress** rather than a fully implemented or certified ISMS.

Controls identified as partially implemented or planned require additional implementation, evidence, testing, or remediation.

Areas requiring continued development may include:

- Identity lifecycle management
- Privileged access management
- Vulnerability management
- Secure development practices
- Logging and monitoring
- Backup and recovery
- Supplier oversight
- Physical security
- Security awareness

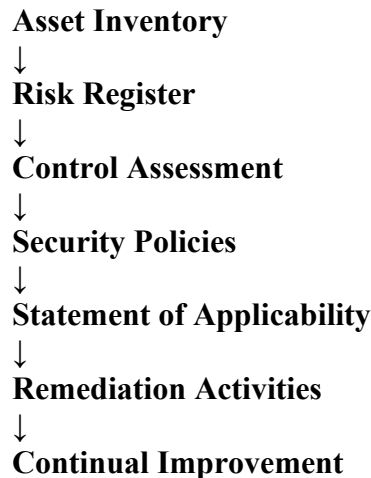
- Formalized operating procedures
- Control testing and evidence collection

These gaps demonstrate a risk-based remediation approach rather than an assumption that every control is immediately effective.

6. Risk and Control Integration

The ISMS maintains traceability from identified risks to control requirements and remediation activities.

The relationship between the primary artifacts is:



The asset inventory informs the risk assessment.

The risk register identifies and prioritizes information security risks.

The control assessment evaluates the effectiveness of relevant safeguards.

Policies establish organizational security requirements.

The Statement of Applicability documents the applicability and implementation status of ISO/IEC 27001:2022 Annex A controls.

Remediation activities address identified gaps and support continual improvement.

7. Remediation and Improvement

Identified control weaknesses and implementation gaps are managed through documented remediation activities.

Remediation priorities should consider:

- Risk severity
- Business impact
- Regulatory requirements
- Contractual requirements
- Security dependencies
- Available resources
- Control effectiveness
- Potential impact to customers and operations

Management should periodically review remediation progress and determine whether additional resources, risk treatment, compensating controls, or changes to information security objectives are required.

8. Performance Monitoring

ISMS performance should be monitored using appropriate security and governance metrics.

Potential metrics include:

- Number and severity of open security risks
- Risk treatment progress
- Control effectiveness
- Remediation completion
- Vulnerability remediation timelines
- Security incident trends
- Access review completion
- Security awareness participation
- Third-party assessment completion
- Business continuity exercise results
- Security monitoring coverage
- Policy review completion

Performance information should be reviewed by responsible owners and incorporated into management review activities.

Trends and recurring deficiencies should be used to identify opportunities for continual improvement.

9. Internal Review and Management Review

The ISMS should be subject to periodic internal review and management review.

Reviews should consider:

- Status of information security objectives
- Risk trends
- Control performance
- Security incidents
- Audit findings
- Remediation progress
- Significant organizational changes
- Technology changes
- Regulatory or contractual changes
- Resource requirements
- Opportunities for improvement

Where deficiencies are identified, corrective actions should be assigned to appropriate owners and tracked through completion.

10. Continual Improvement

Continual improvement is a core component of the modeled ISMS.

The organization should use information from:

- Risk assessments
- Control assessments
- Security incidents
- Business continuity exercises
- Audit findings
- Management reviews
- Security metrics
- Lessons learned
- Changes to the threat landscape

to improve the effectiveness of the ISMS.

Changes to the business, technology environment, regulatory requirements, customer expectations, or threat landscape should trigger review of relevant ISMS documentation and controls.

11. Implementation Roadmap

Near-Term Priorities

Near-term priorities should focus on:

- Closing high-risk control gaps
- Strengthening evidence collection
- Formalizing operational procedures
- Validating implemented controls
- Assigning control owners
- Improving remediation tracking

Medium-Term Priorities

Medium-term priorities should include:

- Recurring control testing
- Supplier reassessment
- Security awareness measurement
- Improved security monitoring
- Business continuity exercises
- Formal internal ISMS reviews
- Periodic access reviews
- Improved vulnerability management

Long-Term Priorities

Longer-term improvement should focus on maintaining the ISMS as a **living management system** rather than treating ISO 27001 documentation as a one-time compliance exercise.

The ISMS should continuously adapt to changes in:

- Business operations
- Technology
- Threats

- Regulations
 - Customer requirements
 - Organizational structure
-

12. Conclusion

Axiom AI's modeled ISMS establishes a coherent governance framework connecting information assets, risks, security controls, policies, responsibilities, objectives, and ISO/IEC 27001:2022 Annex A applicability.

The implementation provides a foundation for continued remediation, evidence development, internal review, and continual improvement.

The project intentionally distinguishes between **documented requirements, implemented controls, partially implemented controls, and remaining gaps** so that the ISMS reflects a realistic implementation and maturity journey.

13. Portfolio Disclaimer

This document is a fictional portfolio demonstration based on a modeled Axiom AI Technologies environment.

It is intended to demonstrate practical GRC, risk management, control assessment, and ISO/IEC 27001 implementation skills.

It does **not** represent an actual certification assessment, independent audit, or certification decision.

14. Implementation Artifact Summary

Artifact	Format	Purpose
Information Security Policy	Word	Establishes overarching information security requirements
Access Control Policy	Word	Defines access and identity management requirements
Incident Response Policy	Word	Defines incident reporting, assessment, response, and lessons learned

Artifact	Format	Purpose
Asset Management Policy	Word	Defines requirements for managing organizational assets
Third-Party Security Policy	Word	Defines security requirements for suppliers and third parties
ISMS Scope Statement	Word	Defines ISMS boundaries and applicability
ISMS Objectives	Word	Defines measurable information security objectives
ISMS Roles & Responsibilities	Word	Assigns ISMS accountability and responsibility
Statement of Applicability	Excel	Documents applicability and implementation status of 93 Annex A controls
Risk Register / Treatment Plan	Excel	Documents identified risks and treatment activities
Control Assessment	Excel	Evaluates control effectiveness and remediation status

15. Document Review

This document should be reviewed **at least annually** and whenever significant changes occur to the organization, technology environment, ISMS scope, information security risks, regulatory requirements, or ISMS governance structure.